TECHWAVES EGY

Blue Team Application & Runtime Security (ARS) v4.0

Email: **info@techwaves-egy.com** | Web: **www.techwaves-egy.com**

CLASSIFICATION: STRICTLY CONFIDENTIAL // SECURITY AUDIT

Application: Enterprise Web Application	**Environment:** Staging	**Mode:** White Box / Full-Spectrum ARS	**Date:** 2026-10-22

Phase 1: Pre-Fix Security Assessment Report (ARS v4.0)

OVERALL APPLICATION & HOST RUNTIME SECURITY POSTURE
Assessed across 12 Security Domains, Host Runtime Engines, and CISA KEV Threat Intel

6.2 / 10.0
MODERATE RISK

■■ CISA KEV & ACTIVE CISA KEV THREAT ALERT: PHP Zend Engine RCE (CVE-2026-109618)
Host runtime discovery identified PHP 8.5.4 (vulnerable range 8.5.0–8.5.11). This flaw is actively cataloged in CISA KEV with observed in-the-wild exploitation. An automatic Emergency Priority (P1 / Critical SLA: 24–48h) has been enforced.

1. Executive Summary

Techwaves EGY performed an enterprise Application & Runtime Security (ARS) assessment evaluating application logic, authorization boundaries, cryptographic hygiene, API integrity, software dependencies, and underlying host execution runtimes (PHP Zend Engine, Node.js V8, Web Server daemons) across 12 security domains. The assessment identified critical vulnerabilities in both application-level access control and the host execution engine requiring immediate remediation.

2. 12-Domain Security Scorecard

#	Security Domain	Score	Rating	Primary Observation
1	Authentication & Session Security	8.0/10	Compliant	MFA active; token lifetime needs shortening.
2	Authorization, RBAC & Tenant Isolation (IDOR)	3.0/10	High Risk	Missing object ownership check on API endpoints.
3	Input Validation & Injection Defenses	4.5/10	High Risk	Dynamic query concatenation identified in search.
4	Output Encoding & XSS Defenses	9.0/10	Hardened	React auto-encoding; strict CSP active.
5	API & Business Logic Integrity	6.0/10	Moderate	Mass assignment on user update DTO.
6	State-Changing Security & CSRF	8.0/10	Compliant	SameSite=Strict cookies active.
7	SSRF & Perimeter Defenses	5.0/10	Moderate	Webhook endpoint lacks RFC 1918 block.
8	File Upload, Path Traversal & Storage	7.5/10	Compliant	S3 isolated storage; needs magic-byte check.
9	Cryptography, Secrets & Transport Security	7.0/10	Compliant	TLS 1.3 active; secrets in Azure KV; key rotation needed.
10	Security Logging, Auditing & SOC Telemetry	4.0/10	High Risk	Missing failed auth logging & correlation ID.
11	Application Supply Chain & Package SCA	7.0/10	Compliant	Dependencies pinned; reachability analysis verified.
12	Host Runtime Engine, Daemon & Infrastructure	2.5/10	Critical Exposure	PHP 8.5.4 vulnerable to Zend Engine RCE (CVE-2026-109618).

3. Infrastructure & Host Runtime Execution Stack

Component	Detected Version	Build / Architecture	Threat Intel / CISA KEV	Posture Status
Host Runtime (PHP)	PHP 8.5.4	Zend Engine v4.5.4 (NTS x64)	■■ CISA KEV / CVE-2026-109618	■ CRITICAL EXPOSURE
Web Server Daemon	Nginx 1.26.1	OpenSSL 3.0.13, HTTP/2 (x64)	Clean / No KEV	■ COMPLIANT
Database Engine	PostgreSQL 16.3	Debian 16.3-1.pgdg120+1 (x64)	Clean / No KEV	■ COMPLIANT
Native SSL Library	OpenSSL 3.0.13	System Shared Library (x64)	Clean / No KEV	■ COMPLIANT

4. Detailed Vulnerability Dockets & Defensive Shields

[APP-001] Insecure Direct Object Reference (IDOR) on Order Retrieval

[DIRECTLY REACHABLE] **HIGH (CVSS 8.6)**

Target: `GET /api/v1/orders/{orderId}`	**CWE:** CWE-639	**Vector:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`
EPSS: 0.742 (74.2% percentile)	**CISA KEV:** No	**ASVS:** V1.4.1, V5.1.3 | **PCI:** Req 6.2.4 | **NIST:** AC-3, SA-11

Description & Analysis: The order retrieval endpoint queries the database by order ID without validating that the requesting authenticated user owns the object or belongs to the authorized tenant.

Proof of Concept Trace:

```
GET /api/v1/orders/5002 HTTP/1.1
Host: app.internal
Authorization: Bearer <UserA_Token>

HTTP/1.1 200 OK -> UserB order data returned (IDOR confirmed)
```

Tier 1: Code-Level / Binary Patch:

```
// VULNERABLE
var order = await _context.Orders.FindAsync(id);

// SECURE (DEFENSIVE CODE)
var userId = _currentUser.GetUserId();
var order = await _context.Orders.FirstOrDefaultAsync(o => o.Id == id && o.UserId == userId);
```

Tier 2: WAF Rule (ModSec / Cloudflare):

```
SecRule REQUEST_URI "@rx ^/api/v1/orders/(\d+)" "id:100201,
phase:2,t:none,pass,nolog,setvar:tx.target_order_id=%{tx.1}
"
# Enforce JWT subject tenancy validation in reverse
proxy/WAF
```

Tier 3: SOC Detection Rule (Sigma):

```
title: Suspicious Multi-Order IDOR Enumeration Attempt
logsource: {category: webserver}
detection:
selection: {cs_method: GET, cs_uri_stem|re:
'^/api/v1/orders/\d+'}
timeframe: 1m
condition: selection | count() by c_ip > 15
level: high
tags: [attack.t1083, attack.t1078]
```

Tier 4: Immediate Config Workaround (Hotfix): `Deploy API gateway parameter validation filter mapping authenticated tenant claim to request context before upstream forwarding.`

[APP-002] Host Runtime: PHP Zend Engine Multipart Parser Remote Execution Defect / RCE [DIRECTLY REACHABLE]

CRITICAL (CVSS 9.8)

Target: `Host Runtime: PHP 8.5.4 via Nginx FastCGI` **CWE:** CWE-122 **Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

EPSS: 0.965 (96.5% percentile) **CISA KEV:** YES (Known In-The-Wild Exploitation) **ASVS:** V14.2.1 | **PCI:** Req 6.2 | **NIST:** SI-2, SA-11

Description & Analysis: Host runtime discovery identified PHP 8.5.4 (Zend Engine v4.5.4). This release suffers from improper boundary calculation and buffer validation flaw in the core multipart body parser. Active CISA KEV in-the-wild exploitation allows remote unauthenticated attackers to execute arbitrary code via specially crafted multipart chunk boundaries.

Proof of Concept Trace:

```
$ php -v
PHP 8.5.4 (cli) (built: Feb 12 2026 14:22:10) (NTS)
Zend Engine v4.5.4, Copyright (c) Zend Technologies
[!] Version falls within known vulnerable range: PHP 8.5.0 - 8.5.11 (CVE-2026-109618)
```

Tier 1: Code-Level / Binary Patch:

```
# Host Runtime Upgrade Procedure
apt-get update && apt-get install --only-upgrade php8.5 php8.5-fpm php8.5-cli
systemctl restart php8.5-fpm && nginx -s reload
# Verify: php -v >= 8.5.12
```

Tier 2: WAF Rule (ModSec / Cloudflare):

```
SecRule REQUEST_HEADERS:Content-Type "@rx
(?i)multipart/form-data;.*boundary=.{128,}"
"id:100301,phase:1,deny,status:400,log,msg:'Potential Zend
Engine Multipart RCE Probe (CVE-2026-109618)'"
```

Tier 3: SOC Detection Rule (Sigma):

```
title: Zend Engine Multipart Boundary Exploit Probe
logsource: {category: webserver}
detection:
selection: {cs_method: POST, c_content_type|contains:
'multipart/form-data'}
suspicious_boundary: {cs_header|re:
'boundary=[\-\=]{60,}[^\r\n]{128,}'}
condition: selection and suspicious_boundary
level: critical
tags: [attack.t1190, attack.t1203]
```

Tier 4: Immediate Config Workaround (Hotfix): `In php.ini: session.upload_progress.enabled = Off; post_max_size = 10M; upload_max_filesize = 10M; max_file_uploads = 5`

5. MANDATORY APPROVAL GATE — AWAITING STAKEHOLDER SIGN-OFF

This document concludes Phase 1 of the Blue-Team-Skills v4.0 assessment. Per enterprise Blue Team operating principles, no application code modifications or remediation scripts will be executed until authorized by the technical lead or system owner.

Verification Checkboxes:

- **[ ] Technical Lead Verification:** All 12 domain scores, CVSS calculations, and reachability traces verified.
- **[ ] Architecture & Change Control:** Maintenance window, backup status, and rollback playbooks approved.
- **[ ] Authorization to Proceed:** Stakeholder clearance granted to initiate Phase 2 (Defensive Remediation & Retesting).

Next Step: Reply with explicit approval (e.g., *'Approved to proceed with Phase 2'*) to start defensive remediation.